

Risk ID	Asset / Process
R01	Customer / Transaction Data
R02	User Identities / Endpoints
R03	Third-Party Services
R04	Information Assets
R05	Payment Application / Source Code
R06	Cloud Infrastructure
R07	Servers / Applications / Endpoints
R08	Logs / Security Monitoring
R09	Incident Management
R10	Payment Service Availability
R11	Personal Information / Records
R12	Source Code / Privileged Access

Risk Statement	Threat / Event
Weak or inconsistently governed access could allow unauthorized access to customer or transaction information, causing confidentiality breach, fraud exposure and loss of trust. Irregular security awareness may enable phishing or social engineering, resulting in credential compromise and unauthorized system access.	Unauthorized access / account misuse Phishing / social engineering
Inconsistent supplier security checks may allow a vulnerable or poorly controlled third party to compromise NovaPay information or services.	Supplier compromise / service failure
Without a formal asset inventory, critical assets may be unmanaged, unowned or incorrectly protected, increasing the likelihood of loss or exposure.	Asset loss / unmanaged exposure
Inadequate secure-development governance may introduce exploitable defects or unauthorized code changes into the payment service.	Application exploitation / unauthorized code change
Unmanaged cloud configuration or access could expose services/data or cause disruption.	Cloud misconfiguration / unauthorized cloud access
Technical vulnerabilities may remain exploitable if identification and remediation are not governed consistently.	Exploitation of known vulnerabilities
Insufficient logging or monitoring could delay detection of account misuse, attacks or transaction-related anomalies.	Undetected malicious activity
Reactive security decision-making may lead to inconsistent incident assessment, escalation, containment and lessons learned.	Delayed or inconsistent incident response
A technology, supplier or cyber disruption could make digital payment services unavailable and materially affect customers and operations.	Cyberattack / technology outage / supplier outage
Failure to identify and meet applicable privacy, legal or contractual requirements could cause regulatory, contractual and reputational harm.	Compliance failure / privacy incident
Excessive privileged or repository access could allow unauthorized disclosure or alteration of source code and production-related configurations.	Privileged misuse / credential compromise

Vulnerability / Cause	Inherent Likelihood	Inherent Impact	Inherent Score
Incomplete access governance and unverified access-review effectiveness	4	5	20
Irregular security awareness training	4	4	16
Inconsistent third-party security due diligence and monitoring	3	5	15
No formal asset inventory or validated ownership	3	4	12
Secure SDLC and security-testing evidence not provided	3	5	15
Cloud security responsibilities, baselines and review evidence not provided	3	4	12
Formal vulnerability-management process and remediation SLA evidence not provided	3	4	12
Logging standards and centralized monitoring evidence not provided	3	4	12
Incident governance and tested response procedures not evidenced	3	4	12
Continuity, recovery objectives and tested recovery evidence not provided	3	5	15
Formal obligations register and control evidence not provided	3	5	15
Privileged and repository access review evidence not provided	2	5	10

Inherent Rating	Existing Control Evidence	Current Residual
Critical	No verified control-effectiveness evidence provided in the case study.	4
Critical	Training exists but is irregular; effectiveness evidence is not provided.	4
Critical	Third-party checks occur but are inconsistent; no effectiveness evidence is provided.	3
High	No formal asset inventory exists.	3
Critical	Current secure-development control evidence is not provided.	3
High	The case confirms cloud-based systems but not current cloud security controls.	3
High	No verified vulnerability-management evidence is provided.	3
High	No verified monitoring-control evidence is provided.	3
High	The case indicates reactive security decision-making; response effectiveness is not evidenced.	3
Critical	No verified continuity or recovery-test evidence is provided.	3
Critical	The portfolio scenario places NovaPay in Ireland. A formal obligations register covering applicable Irish and EU requirements, including GDPR where relevant, is not provided.	3
High	No verified privileged-access review evidence is provided.	2

Current Residual	Current Residual	Current Residual	Treatment
5	20	Critical	Mitigate
4	16	Critical	Mitigate
5	15	Critical	Mitigate / Share
4	12	High	Mitigate
5	15	Critical	Mitigate
4	12	High	Mitigate
4	12	High	Mitigate
4	12	High	Mitigate
4	12	High	Mitigate
5	15	Critical	Mitigate / Share
5	15	Critical	Mitigate
5	10	High	Mitigate

Treatment Action	Proposed Owner
Implement role-based access, identity lifecycle controls, secure authentication/MFA, periodic access reviews and security logging.	IT/Security + Business Owners
Formalize awareness training, phishing education, event reporting and strong authentication.	GRC/HR + IT
Tier suppliers by risk; perform due diligence; include security clauses; monitor critical suppliers and cloud services.	GRC/Procurement/IT
Create asset inventory; assign owners; classify information; define acceptable-use and lifecycle requirements.	IT/GRC + Asset Owners
Establish secure SDLC, application security requirements, secure coding, security testing and controlled changes.	Engineering + Security
Establish cloud security responsibilities, configuration baselines, access controls and periodic review.	Cloud/IT + Security
Implement vulnerability scanning, risk-based remediation SLAs, exception handling and tracking.	IT/Security
Define logging standards, centralize security-relevant logs, alert on priority events and review monitoring effectiveness.	Security/IT
Document incident roles, severity criteria, response procedures, evidence handling and lessons learned; run a tabletop exercise.	Security/GRC/Management
Complete business impact analysis; define recovery objectives; test backups, continuity and supplier dependencies.	Operations/IT/Management
Maintain obligations register; implement privacy/PII controls; retain evidence and periodically review compliance.	GRC/Legal/Management
Restrict privileged and source-code access; review entitlements; protect repositories; log administrative actions.	Engineering/IT/Security

Target Timeline	Target Likelihood	Target Impact	Target Residual	Target Residual	Status
Months 2-4	2	5	10	High	Open
Months 2-3	2	4	8	Moderate	Open
Months 2-4	2	5	10	High	Open
Weeks 2-6	2	4	8	Moderate	Open
Months 2-4	2	5	10	High	Open
Months 2-4	2	4	8	Moderate	Open
Months 2-4	2	4	8	Moderate	Open
Months 2-4	2	4	8	Moderate	Open
Months 2-5	2	4	8	Moderate	Open
Months 3-5	2	5	10	High	Open
Months 2-5	2	5	10	High	Open
Months 2-4	1	5	5	Moderate	Open